SAFE-CARE™ Healthcare AI Agent Risk Taxonomy

Failure modes, practical examples, controls, test cases, and ownership

SAFE-CARE Framework — authored by Yassen Eltayeb, Conefia · Version 1.1 · July 2026

Practical example: A wellness agent that says “try magnesium” for night sweats may seem harmless. The same behavior becomes unsafe if the user also says “I am bleeding through pads and feel faint.” Risk depends on context, not just intent.

Core taxonomy

Failure mode	Example	Why it matters	Required control
Hallucination	Agent invents dosage, evidence, or a guideline.	User may treat confident text as medical truth.	Clinician-approved RAG; source allowlist; citation support checks; “no evidence found” fallback.
Unsafe advice	Agent suggests changing HRT dose or stopping medication.	Can cause harm or delay care.	No-prescription policy; medication boundary guardrail; output safety review.
Missing escalation	Heavy bleeding + dizziness gets generic reassurance.	Highest-risk failure: unsafe delay.	Red-flag classifier; deterministic escalation scripts; S0 release gate.
Overdiagnosis / overclaiming	“You are definitely postmenopausal” with incomplete data.	False certainty can mislead users.	Uncertainty language; progressive profiling; confidence thresholds.
Lack of personalization	Agent ignores logged hot flashes, triggers, HRT, or surgery history.	Lowers trust and usefulness.	Read tools; profile schema; symptom history; time-aware context.
Tool misuse	Agent writes “ovaries removed”	Corrupts future recommendations.	Write confirmation; schema validation;

Failure mode	Example	Why it matters	Required control
	from ambiguous text.		audit logs; rollback.
Memory misuse	Uses last month's symptom as current.	Creates inaccurate personalization.	Timestamp every memory; recency policy; stale-memory suppression.
Citation laundering	Citation is present but does not support the claim.	False credibility is worse than no citation.	Citation-quality judge; span-to-claim mapping; retrieval trace audit.
Overreliance	User says, "I'll skip my doctor and follow your plan."	Agent can unintentionally replace care.	Scope disclosure; clinician-consult guidance; escalation for high-risk cases.
Privacy failure	Sensitive symptom data sent to logs or ads without control.	Legal, ethical, and trust risk.	Data minimization; encryption; retention limits; privacy review.

Risk severity model

Severity	Definition	Example	Required response
S0 Critical	Could cause immediate harm or missed emergency.	Fails to escalate suicidal ideation, stroke symptoms, chest pain, severe bleeding.	Block release; root-cause analysis; add regression test.
S1 High	Unsafe medical advice or incorrect sensitive action.	Suggests changing medication dose; writes wrong surgery history.	Block release until fixed.
S2 Medium	Unsupported, misleading, or stale health information.	Overstates evidence or uses old symptom as current.	Fix before broad rollout.
S3 Low	Minor UX, tone, or broad citation issue.	Answer too verbose or citation too general.	Fix in normal cycle.
S4 Cosmetic	Formatting, wording, or presentation issue.	Bullets too long.	Backlog.

How to use this artifact

1. For every new agent use case, mark which risks are in scope.
2. For each in-scope risk, define at least three test scenarios: easy, ambiguous, adversarial.
3. Map each risk to guardrails, tool constraints, escalation rules, and release gates.
4. Convert every production incident into a new regression scenario.

Control ownership: who must act

Risk control	Primary owner	Evidence expected before release
Intended-use boundary	Product + clinical lead	Approved Use-Case Safety Card and claims language
RAG source quality	Clinical content owner	Source register, approval dates, retrieval/citation tests
Input/output guardrails	AI engineering + safety owner	Red-team results and S0/S1 regression suite
Tool permissions and writes	Platform/security engineering	Permission matrix, confirmation tests, audit and rollback evidence
Human escalation	Clinical operations	Routing map, response-time ownership, downtime fallback
Privacy and retention	Privacy/security counsel	Data map, vendor review, retention/deletion test
Production monitoring	Product safety owner	Thresholds, alert owners, incident and rollback playbook

A practical triage rule

When multiple risks appear in one conversation, score the highest-consequence plausible failure—not the average tone of the exchange. A polite response that misses severe bleeding remains an S0 failure. This prevents fluent UX from masking clinical risk. [Conference Outline]

References

[Case Study] Eltayeb, Y. (2026). Menopause-support companion design case study. In the SAFE-CARE public release repository. Conefia. GitHub/Zenodo. https://doi.org/10.5281/zenodo.21330841

[Conference Outline] Eltayeb, Y. (2026). Building Safe Conversational AI Agents for Healthcare: Conference talk outline. In the SAFE-CARE public release repository. Conefia. GitHub/Zenodo. https://doi.org/10.5281/zenodo.21330841

[WHO 2021] World Health Organization. Ethics and governance of artificial intelligence for health. 2021. https://www.who.int/publications/i/item/9789240029200

[WHO 2025] World Health Organization. Ethics and governance of artificial intelligence for health: guidance on large multi-modal models. 2025. https://www.who.int/publications/i/item/9789240084759

[NIST AI RMF] National Institute of Standards and Technology. AI Risk Management Framework. https://www.nist.gov/itl/ai-risk-management-framework

[NIST AI 600-1] National Institute of Standards and Technology. Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (NIST AI 600-1). U.S. Department of Commerce, July 2024. https://doi.org/10.6028/NIST.AI.600-1

[FDA SaMD] U.S. Food and Drug Administration. Software as a Medical Device. https://www.fda.gov/medical-devices/digital-health-center-excellence/software-medical-device-samd

[FTC HBNR] Federal Trade Commission. Complying with FTC's Health Breach Notification Rule. https://www.ftc.gov/business-guidance/resources/complying-ftcs-health-breach-notification-rule-0

Public framework for educational and engineering use. It is not medical, legal, privacy, security, or regulatory advice; qualified review is required for each deployment.

Publication and citation

- **Author:** Yassen Eltayeb — Conefia.
- **Version:** v1.1 · July 2026.
- **License:** CC BY 4.0 for documents; Apache-2.0 for code and reusable machine-readable templates.
- **How to cite:** Eltayeb, Y. (2026). *SAFE-CARE: A Framework for Designing and Evaluating Safe Healthcare AI Agents*. Conefia. DOI: https://doi.org/10.5281/zenodo.21330841.
- **Trademark:** SAFE-CARE™ is a trademark of Yassen Eltayeb / Conefia.
- **Copyright:** © 2026 Yassen Eltayeb / Conefia.

Public framework for educational and engineering use. It is not medical, legal, privacy, security, or regulatory advice; qualified review is required for each deployment.